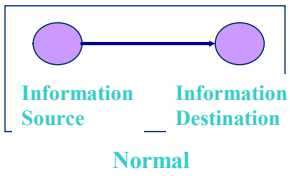
Security Attacks - Taxonomy



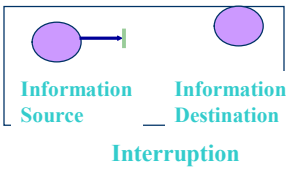
- Interruption – attack on *availability*
- Interception – attack on *confidentiality*
- Modification – attack on *integrity*
- Fabrication – attack on *authenticity*

Properties that are compromised

3

Interruption

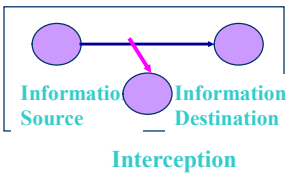
- Causes *denial of services*.
- Information resources (hardware, software and data) are deliberately made unavailable, lost or unusable, usually through malicious destruction.



4

Interception

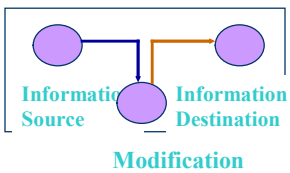
- Also known as ***un-authorised access***.
- Difficult to trace as no traces of intrusion might be left.
- e.g: illegal eavesdropping or wiretapping or sniffing, illegal copying.



5

Modification

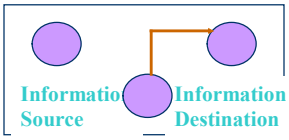
- Also known as *tampering with a resource*.
- Resources can be data, programs, hardware devices, etc.
  - E.g: intercept a message, change and send it



6

Fabrication

- also known as *counterfeiting* (of objects such as data, programs, devices, etc).
- Allows to by pass the authenticity checks.
- e.g: insertion of spurious messages in a network, adding a record to a file, counterfeit bank notes, fake cheques,…
- *impersonation/masquerading*
  - To pretend some authorised entity to gain access to data, services etc.



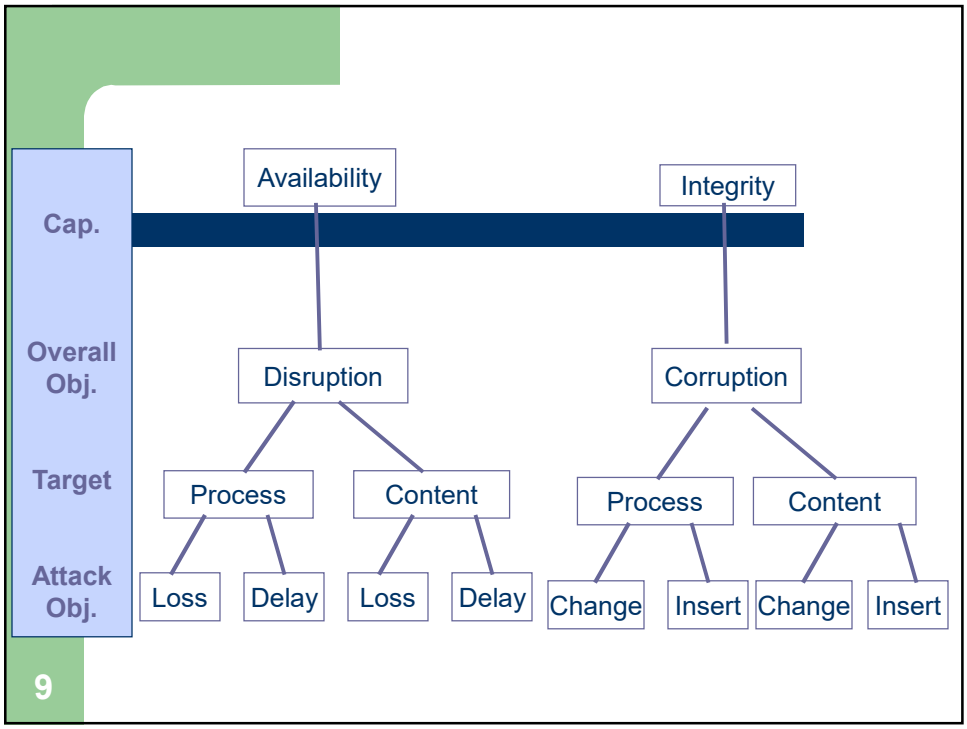
Fabrication

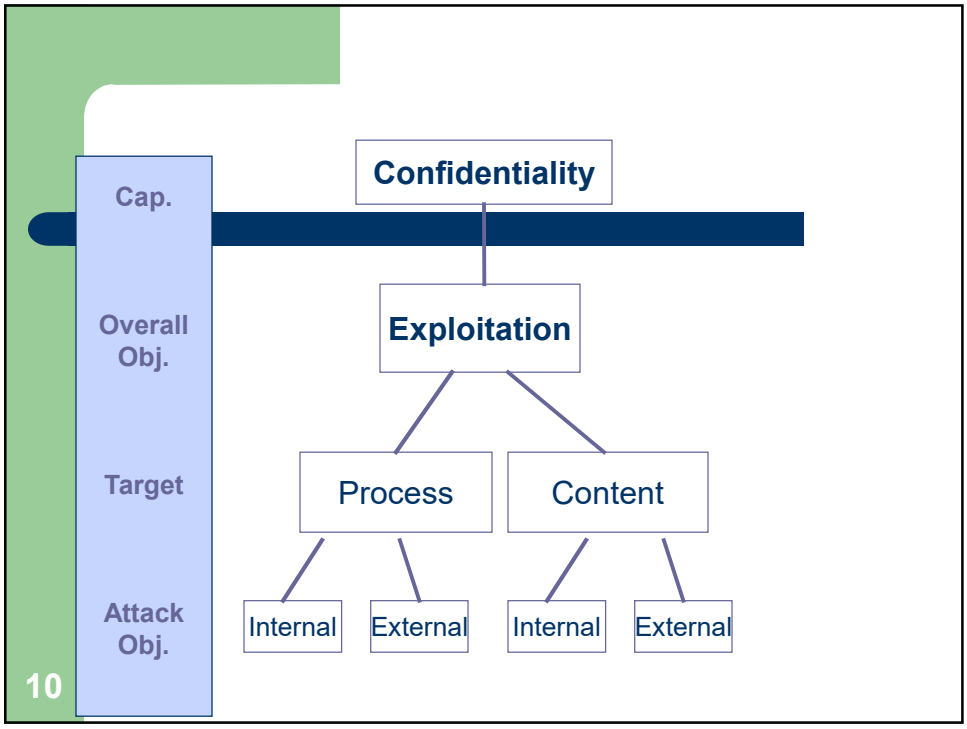
7

Attacks

- Attacks can be categorised in many ways
  - Capability attacked
  - Overall objective
  - Target
  - Attack objective

8


Cap.
Overall Obj.
Target
Attack Obj.
Availability
Integrity
Disruption
Corruption
Process
Content
Process
Content
Loss
Delay
Loss
Delay
Change
Insert
Change
Insert
9


Cap.
Overall Obj.
Target
Attack Obj.
Confidentiality
Exploitation
Process
Content
Internal
External
Internal
External
10

Countermeasures

- Detection: an attack may be undetected, detected on occurrence, detected some time after the occurrence
- Response: can be no response, initiate audit activities, mitigate further damage, initiate protective action
- Recover

11

Security Service

- enhance security of data processing systems and information transfers of an organization
- intended to counter security attacks
- using one or more security mechanisms
- often replicates functions normally associated with physical documents
  - which, for example, have signatures, dates; need protection from disclosure, tampering, or destruction; be notarized or witnessed; be recorded or licensed

12

Security Services

- X.800:
  "a service provided by a protocol layer of communicating open systems, which ensures adequate security of the systems or of data transfers"
- RFC 2828:
  "a processing or communication service provided by a system to give a specific kind of protection to system resources"

13

Security Services (X.800)

- **Authentication** - assurance that the communicating entity is the one claimed
- **Access Control** - prevention of the unauthorized use of a resource
- **Data Confidentiality** –protection of data from unauthorized disclosure
- **Data Integrity** - assurance that data received is as sent by an authorized entity
- **Non-Repudiation** - protection against denial by one of the parties in a communication

14

Security Mechanism

- feature designed to detect, prevent, or recover from a security attack
- no single mechanism that will support all services required
- one particular element underlies many of the security mechanisms in use:
  - **cryptographic techniques**
- hence our focus on this topic

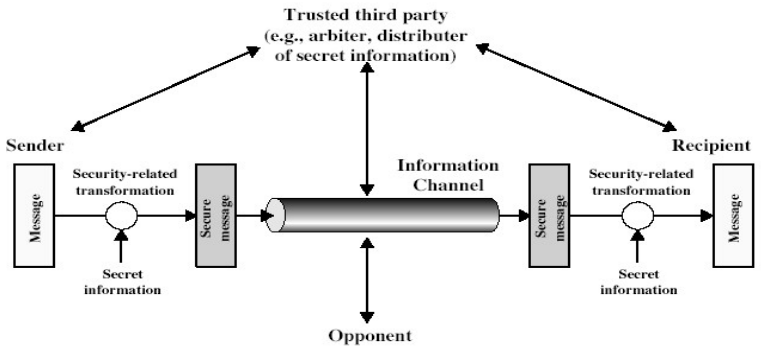
15

Security Mechanisms (X.800)

- specific security mechanisms:
  - encipherment, digital signatures, access controls, data integrity, authentication exchange, routing control, notarization
- pervasive security mechanisms:
  - trusted functionality, event detection, security audit trails, security recovery

16

Model for Network Security



17

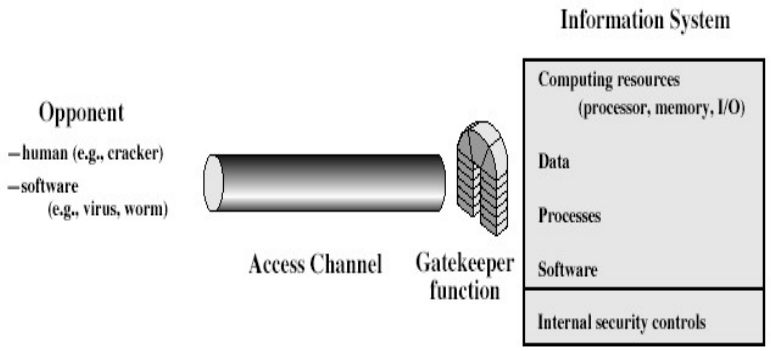
Model for Network Security

using this model requires us to:

1. design a suitable algorithm for the security transformation
2. generate the secret information (keys) used by the algorithm
3. develop methods to distribute and share the secret information
4. specify a protocol enabling the principals to use the transformation and secret information for a security service

18

Model for Network Access Security



19

Model for Network Access Security

using this model requires us to:

1. select appropriate gatekeeper functions to identify users
2. implement security controls to ensure only authorised users access designated information or resources

trusted computer systems may be useful to help implement this model

20

Decide what/where to control

- What should be the focus of the controls?
  - should protection mechanisms focus on data or operations on that data or on the users who use the data?
- Since there are layers of technology, where should controls be applied ?
  - Applications, operating systems, hardware.

21

Study Effectiveness of Controls

- Merely having controls does no good unless they are used properly. The factors that affect the effectiveness are
  - Awareness of protection
  - Likelihood of users
  - Overlapping controls
  - Periodic review

22

Methods of Defence

- Based on the objects
  - Physical controls
    - Lock, guards, backup of data and software, thick walls, …
  - Hardware
    - Apply security devices, smart cards…
  - Software controls
    - Set up firewall, install software to enforce authentication, etc...

23

Methods of Defence

- Based on the mechanisms
  - Prevention:
    - *Cryptographic techniques*
    - Find weakness before attack
    - Secure communications/ firewalls
  - Detection:
    - Detect attempts and successful security violations
  - Recovery:
    - Use Backup recovery software to check the systems and recover

24

Methods of defence

- Need to be done
  - Regularly check systems for security holes
  - Study new software carefully before install or update your systems
  - Carry out and review company security polices and procedures
  - Educate users

25

Cryptography

26

Cryptography

- characterize cryptographic system by:
  - number of keys used
    - single-key or private / two-key or public
  - type of encryption operations used
    - substitution / transposition / product
  - way in which plaintext is processed
    - block / stream

symetri asymetri

dilakukan pergantian mengubah posisi tempat

27

Symmetric Encryption

- or conventional / private-key / single-key
- sender and recipient share a common key
- all classical encryption algorithms are private-key
- was only type prior to invention of public-key in 1970's
- and by far most widely used

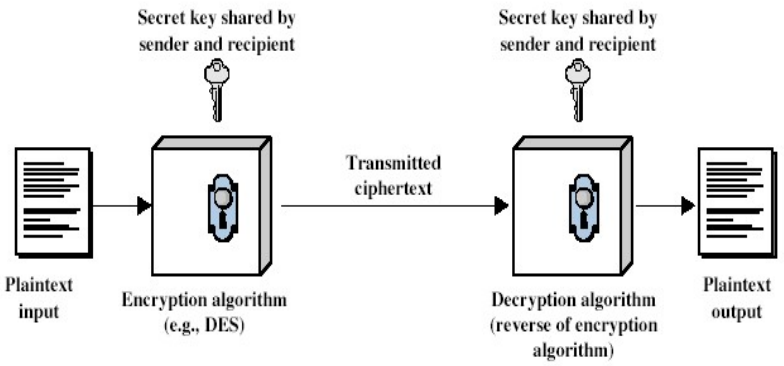
28

Some Basic Terminology

- **plaintext** - original message
- **ciphertext** - coded message
- **cipher** - algorithm for transforming plaintext to ciphertext
- **key** - info used in cipher known only to sender/receiver
- **encipher (encrypt)** - converting plaintext to ciphertext
- **decipher (decrypt)** - recovering ciphertext from plaintext
- **cryptography** - study of encryption principles/methods
- **cryptanalysis (codebreaking)** - study of principles/ methods of deciphering ciphertext *without* knowing key
- **cryptology** - field of both cryptography and cryptanalysis

29

Symmetric Cipher Model



30

Requirements

- two requirements for secure use of symmetric encryption:
  - a strong encryption algorithm
  - a secret key known only to sender / receiver
- mathematically have:
  - $C = E_K(P)$ chiper = encrypt key (plaintext)
  - $P = D_K(C)$
- assume encryption algorithm is known KUNCI DIJAGA kesadaran kalo orang lain bisa tau dan akhirnya bisa dievaluasi
- implies a secure channel to distribute key

31

Cryptanalysis mengembalikan menjadi plain text tanpa punya key

- objective to recover key not just message
- general approaches:
  - cryptanalytic attack
  - brute-force attack

dictionary attack untuk menyimpan data yang memungkinkan

32

Cryptanalytic Attacks

- **ciphertext only**
  - only know algorithm & ciphertext, is statistical, know or can identify plaintext
- **known plaintext** bisa memperkirakan plaintextnya
  - know/suspect plaintext & ciphertext
- **chosen plaintext**
  - select plaintext and obtain ciphertext
- **chosen ciphertext**
  - select ciphertext and obtain plaintext
- **chosen text**
  - select plaintext or ciphertext to en/decrypt

33

More Definitions

- **unconditional security** sumber daya tinggi
  - no matter how much computer power or time is available, the cipher cannot be broken since the ciphertext provides insufficient information to uniquely determine the corresponding plaintext
- **computational security**
  - given limited computing resources (eg time needed for calculations is greater than age of universe), the cipher cannot be broken

34

Brute Force Search

- always possible to simply try every key
- most basic attack, proportional to key size
- assume either know / recognise plaintext

Key Size (bits)	Number of Alternative Keys	Time required at 1 decryption/μs	Time required at 10^6 decryptions/μs
32	$2^{32} = 4.3 \times 10^9$	2^{31} μs = 35.8 minutes	2.15 milliseconds
56	$2^{56} = 7.2 \times 10^{16}$	2^{55} μs = 1142 years	10.01 hours
128	$2^{128} = 3.4 \times 10^{38}$	2^{127} μs = 5.4×10^{24} years	5.4×10^{18} years
168	$2^{168} = 3.7 \times 10^{50}$	2^{167} μs = 5.9×10^{36} years	5.9×10^{30} years
26 characters (permutation)	$26! = 4 \times 10^{26}$	2×10^{26} μs = 6.4×10^{12} years	6.4×10^6 years

35

Classical Substitution Ciphers

- where letters of plaintext are replaced by other letters or by numbers or symbols
- or if plaintext is viewed as a sequence of bits, then substitution involves replacing plaintext bit patterns with ciphertext bit patterns

36

Caesar Cipher

- earliest known substitution cipher
- by Julius Caesar
- first attested use in military affairs
- replaces each letter by 3rd letter on
  - example:

```
engineering students
HQJLQHHULQJ VWXGHQWV
```

37

Caesar Cipher

- can define transformation as:

```
a b c d e f g h i j k l m n o p q r s t u v w x y z
D E F G H I J K L M N O P Q R S T U V W X Y Z A B C
```

- mathematically give each letter a number

```
a b c d e f g h i j  k  l  m  n  o  p  q  r  s  t  u  v  w  x  y  z
0 1 2 3 4 5 6 7 8 9 10 11 12 13 14 15 16 17 18 19 20 21 22 23 24 25
```

- then have Caesar cipher as:

  $c = E(p) = (p + k) \bmod (26)$

  $p = D(c) = (c - k) \bmod (26)$

38

Cryptanalysis of Caesar Cipher

- only have 26 possible ciphers
  - A maps to A,B,..Z
- could simply try each in turn
- a **brute force search**
- given ciphertext, just try all shifts of letters
- do need to recognize when have plaintext
  - eg. break ciphertext “RUD ZHUXK"

39

Monoalphabetic Cipher

- rather than just shifting the alphabet
- could shuffle the letters arbitrarily
- each plaintext letter maps to a different random ciphertext letter
- hence key is 26 letters long

Plain: `abcdefghijklmnopqrstuvwxyz`
Key: `DKVQFIBJWPESCXHTMYAUOLRGZN`

Plaintext: `informatics`
Ciphertext: `WXIHYCDUWVA`

40

Monoalphabetic Cipher Security

- now have a total of 26! = 4 x 10^26 keys
- with so many keys, might think is secure
- but would be **!!!WRONG!!!**
- problem is language characteristics

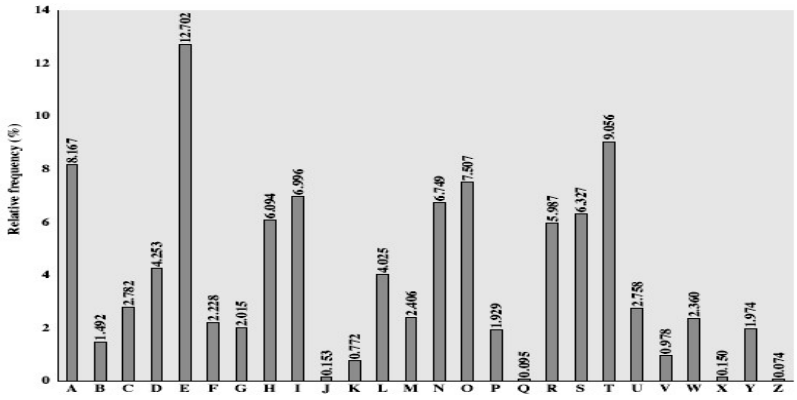
41

Language Redundancy and Cryptanalysis

- human languages are **redundant**
  - eg "th lrd s m shll nt wnt"
- letters are not equally commonly used
- in English *E* is by far the most common letter
  - followed by T,R,N,I,O,A,S
  - other letters like Z,J,K,Q,X are fairly rare
- have tables of single, double & triple letter frequencies for various languages

42

English Letter Frequencies



43

Use in Cryptanalysis

- key concept - monoalphabetic substitution ciphers do not change relative letter frequencies
- discovered by Arabian scientists (Abu al-Kindi) in 9th century
- calculate letter frequencies for ciphertext
- compare counts/plots against known values
- if caesar cipher look for common peaks/troughs
  - peaks at: A-E-I triple, NO pair, RST triple
  - troughs at: JK, X-Z
- for monoalphabetic must identify each letter
  - tables of common double/triple letters help

44

Example Cryptanalysis

- given ciphertext:

```
UZQSOVUOHXMOPVGPOZPEVSGZWSZOPFPESXUDBMETSXAIZ
VUEPHZHMDZSHZOWSFPAPPDTSVPQUZWYMXUZUHSX
EPYEPOPDZSZUFPOMBZWPFUPZHMDJUDTMOHMQ
```

- count relative letter frequencies
- guess *P* & *Z* are *e* and *t*
- guess *ZW* is *th* and hence *ZWP* is *the*
- proceeding with trial and error finally get:

```
it was disclosed yesterday that several informal but
direct contacts have been made with political
representatives of the viet cong in moscow
```

45

Playfair Cipher

- not even the large number of keys in a monoalphabetic cipher provides security
- one approach to improving security was to encrypt multiple letters
- the **Playfair Cipher** is an example
- invented by Charles Wheatstone in 1854, but named after his friend Baron Playfair

46

Playfair Key Matrix

- a 5X5 matrix of letters based on a keyword
- fill in letters of keyword
- fill rest of matrix with other letters
- eg. using the keyword MONARCHY

M	O	N	A	R
C	H	Y	B	D
E	F	G	I/J	K
L	P	Q	S	T
U	V	W	X	Z

47

Encrypting and Decrypting

- plaintext is encrypted two letters at a time
  1. if a pair is a repeated letter, insert filler like 'X'
  2. if both letters fall in the same row, replace each with letter to right (wrapping back to start from end)
  3. if both letters fall in the same column, replace each with the letter below it (again wrapping to top from bottom)
  4. otherwise each letter is replaced by the letter in the same row and in the column of the other letter of the pair

48

Playfair Key Matrix

U	N	I/J	V	E
R	S	A	L	B
C	D	F	G	H
K	M	O	P	Q
T	V	X	Y	Z

- Keyword: UNIVERSAL
- Plaintext: informatika
- Digrams: `in fo rm at ik ax`
- Ciphertext: `VIOXSKRXUOFI`

49

Security of Playfair Cipher

- security much improved over monoalphabetic
- since have 26 x 26 = 676 digrams
- would need a 676 entry frequency table to analyse (26 for a monoalphabetic)
  - and correspondingly more ciphertext
- was widely used for many years
  - eg. by US & British military in WW1
- it **can** be broken, given a few hundred letters
  - since still has much of plaintext structure

50

Polyalphabetic Ciphers

- **polyalphabetic substitution ciphers**
- improve security using multiple cipher alphabets
- make cryptanalysis harder with more alphabets to guess and flatter frequency distribution
- use a key to select which alphabet is used for each letter of the message
- use each alphabet in turn
- repeat from start after end of key is reached

51

Vigenère Cipher

- simplest polyalphabetic substitution cipher
- effectively multiple caesar ciphers
- key is multiple letters long $K = k_1\ k_2\ ...\ k_d$
- i^{th} letter specifies i^{th} alphabet to use
- use each alphabet in turn
- repeat from start after d letters in message
- decryption simply works in reverse

52

Example of Vigenère Cipher

- write the plaintext out
- write the keyword repeated above it
- use each key letter as a caesar cipher key
- encrypt the corresponding plaintext letter
- eg using keyword *deceptive*

```
key:           deceptivedeceptivedeceptive
plaintext:     wearediscoveredsaveyourself
ciphertext:    ZICVTWQNGRZGVTWAVZHCQYGLMGJ
```

53

Aids

- simple aids can assist with en/decryption
- a **Saint-Cyr Slide** is a simple manual aid
  - a slide with repeated alphabet
  - line up plaintext 'A' with key letter, eg 'C'
  - then read off any mapping for key letter
- can bend round into a **cipher disk**
- or expand into a **Vigenère Tableau**

54

Security of Vigenère Ciphers

- have multiple ciphertext letters for each plaintext letter
- hence letter frequencies are obscured
- but not totally lost
- start with letter frequencies
  - see if look monoalphabetic or not
- if not, then need to determine number of alphabets, since then can attach each

55

Kasiski Method

- method developed by Babbage / Kasiski
- repetitions in ciphertext give clues to period
- so find same plaintext an exact period apart
- which results in the same ciphertext
- of course, could also be random fluke
- eg repeated “VTW” in previous example
- suggests size of 3 or 9
- then attack each monoalphabetic cipher individually using same techniques as before

56

Autokey Cipher

- ideally want a key as long as the message
- Vigenère proposed the **autokey** cipher
- with keyword is prefixed to message as key
- knowing keyword can recover the first few letters
- use these in turn on the rest of the message
- but still have frequency characteristics to attack
- eg. given key *deceptive*

```
key:         deceptivewearediscoveredsav
plaintext:   wearediscoveredsaveyourself
ciphertext:  ZICVTWQNGKZEIIGASXSTSLVVWLA
```

57

One-Time Pad

- if a truly random key as long as the message is used, the cipher will be secure
- called a One-Time pad
- is unbreakable since ciphertext bears no statistical relationship to the plaintext
- since for **any plaintext** & **any ciphertext** there exists a key mapping one to other
- can only use the key **once** though
- problems in generation & safe distribution of key

58

Transposition Ciphers

- now consider classical **transposition** or **permutation** ciphers
- these hide the message by rearranging the letter order
- without altering the actual letters used
- can recognise these since have the same frequency distribution as the original text

59

Rail Fence cipher

- write message letters out diagonally over a number of rows
- then read off cipher row by row
- Eg.: 'meet me after the toga party'
  - write message out as:

```
m e m a t r h t g p r y
  e t e f e t e o a a t
```

- giving ciphertext

```
MEMATRHTGPRYETEFETEOAAT
```

60

Row Transposition Ciphers

- a more complex transposition
- write letters of message out in rows over a specified number of columns
- then reorder the columns according to some key before reading off the rows

```
Key:        4 3 1 2 5 6 7
Plaintext:  a t t a c k p
            o s t p o n e
            d u n t i l t
            w o a m x y z
```

Ciphertext: `TTNAAPTMTSUOAODWCOIXKNLYPETZ`

61

Product Ciphers

- ciphers using substitutions or transpositions are not secure because of language characteristics
- hence consider using several ciphers in succession to make harder, but:
  - two substitutions make a more complex substitution
  - two transpositions make more complex transposition
  - but a substitution followed by a transposition makes a new much harder cipher

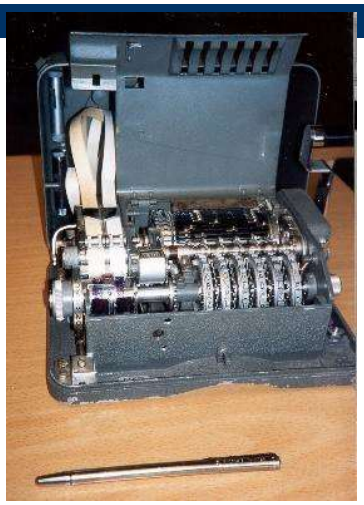
62

Rotor Machines

- before modern ciphers, rotor machines were most common complex ciphers in use
- widely used in WW2
  - German Enigma, Allied Hagelin, Japanese Purple
- implemented a very complex, varying substitution cipher
- used a series of cylinders, each giving one substitution, which rotated and changed after each letter was encrypted
- with 3 cylinders have 26^3=17576 alphabets

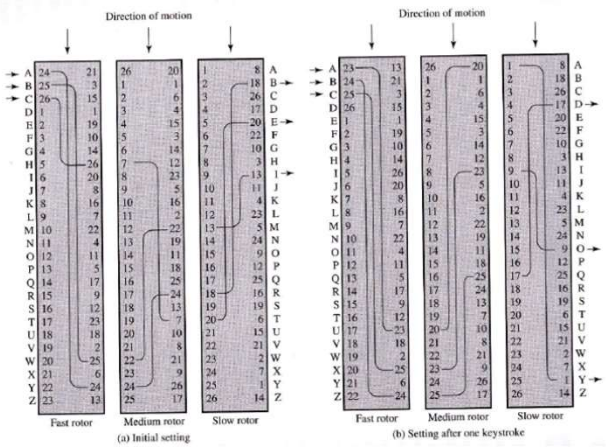
63

Hagelin Rotor Machine



64

Three rotor machine



65

Summary

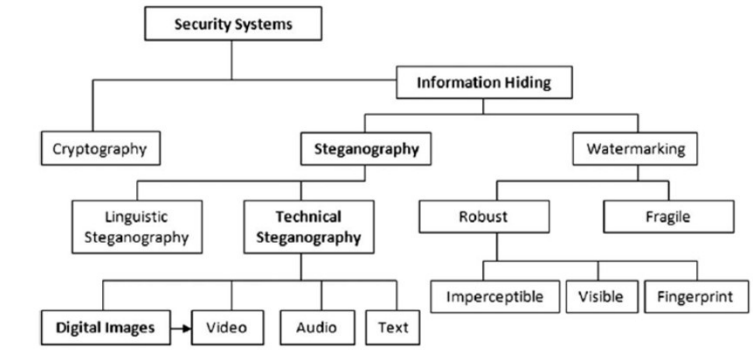
- have considered:
  - classical cipher techniques and terminology
  - monoalphabetic substitution ciphers
  - cryptanalysis using letter frequencies
  - Playfair cipher
  - polyalphabetic ciphers
  - transposition ciphers
  - product ciphers and rotor machines
  - steganography

66

Steganography

- an alternative to encryption
- hides existence of message
  - using only a subset of letters/words in a longer message marked in some way
  - using invisible ink
  - hiding in LSB in graphic image or sound file
- has drawbacks
  - high overhead to hide relatively few info bits

67



Digital image steganography: Survey and analysis of current methods

Abbas Cheddad *, Joan Condell, Kevin Curran, Paul Mc Kevitt

68